INFORME TECNICO

Auditoria de controles y hardening controlado en GNS3

Cisco 7200 | Cisco vIOS L2 | FortiGate 7.0.9 | Kali Linux

Proyecto academico · Evidencia de topologia, conectividad, auditoria PRE y verificacion POST

Fecha del documento: 13 de noviembre de 2026

Alcance del informe

Este documento describe la topologia observada, las pruebas de conectividad y el uso del auditor para un subconjunto de recomendaciones. No representa una certificacion CIS ni una evaluacion integral de seguridad.

Aviso de seguridad: las imagenes incluidas fueron seleccionadas y recortadas para no publicar credenciales ni la direccion DHCP externa de FortiGate port1. No se incluyen volcados completos de configuracion ni respaldos privados.

1. Objetivo y alcance

La practica implementa un laboratorio en GNS3 y demuestra que una estacion Kali Linux puede alcanzar los equipos de red y ejecutar una auditoria automatizada de configuracion por SSH. El flujo contempla auditoria PRE, vista de sugerencias y, cuando se autoriza de forma interactiva, Apply seguido de una comprobacion POST.

El auditor evalua condiciones locales implementadas para controles CIS seleccionados. PASS significa que la condicion codificada encontro evidencia favorable; no significa cumplimiento integral, certificacion ni validacion independiente de todo el benchmark.

2. Topologia y direccionamiento

El diagrama vectorial se encuentra en diagramas/topologia_tecnica.svg.

Nodo / interfaz	Direccion observada	Funcion
Kali eth0	10.20.98.10/24	Estacion de auditoria en LAN de administracion
FortiGate port3	10.20.98.1/24	Gateway de la LAN de administracion
SW1 VLAN 1	10.20.98.2/24	Direccion de gestion del switch
FortiGate port2	10.20.79.2/30	Extremo del enlace de transito a R1
R1	10.20.79.1/30	Router Cisco 7200
FortiGate port1	DHCP externo	Enlace a Cloud1; preservado y sin publicar IP dinamica

Las versiones observadas/declaradas son Cisco IOS 15.2 para R1 y SW1 y FortiOS 7.0.9 para FW1. La captura del informe identifica R1 como 15.2(4)S6; no se atribuye esa subversion a SW1.

3. Evidencia visual del laboratorio

Las capturas documentan el escenario, la direccion de Kali, interfaces relevantes de FortiGate, VLAN de gestion y pruebas ICMP. Se preservan los nombres y estados observables sin exponer informacion externa innecesaria.

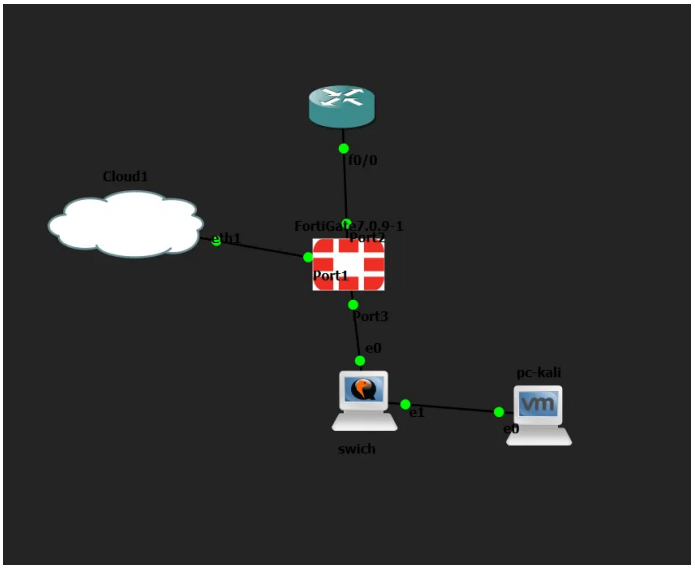


Figura 2. Captura original del proyecto GNS3. Las etiquetas se complementan con el diagrama vectorial.

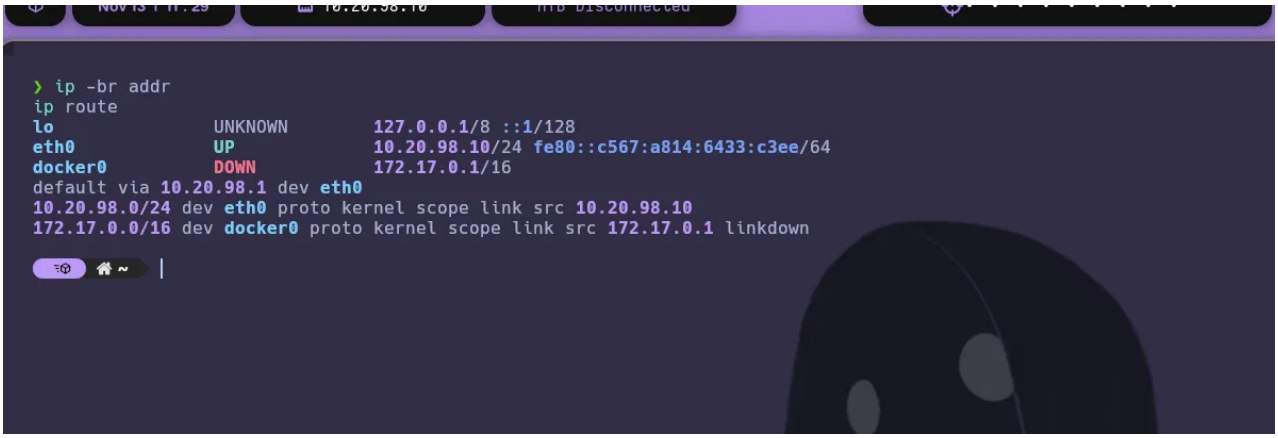


Figura 3. Kali en 10.20.98.10/24 y ruta por defecto visible en la LAN del laboratorio.

3. Evidencia visual (continuacion)

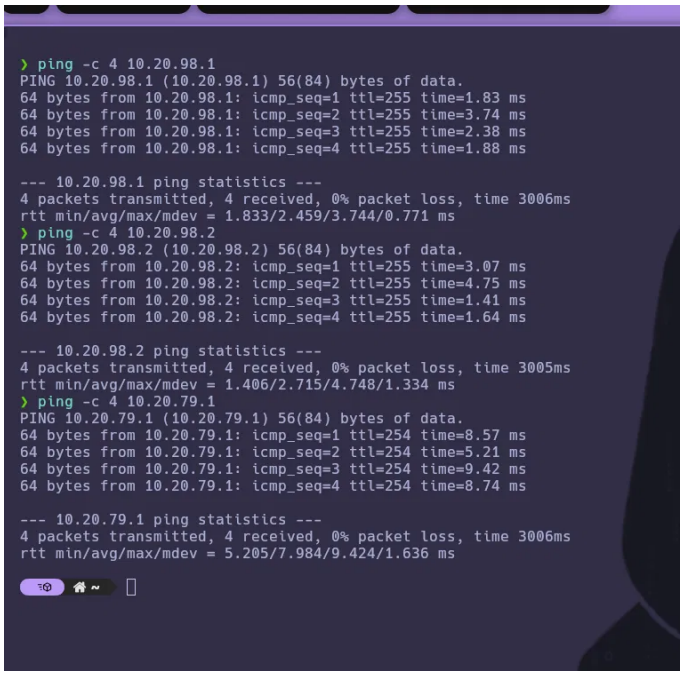


Figura 4. Pruebas desde Kali: 4 de 4 respuestas de 10.20.98.1, 10.20.98.2 y 10.20.79.1.

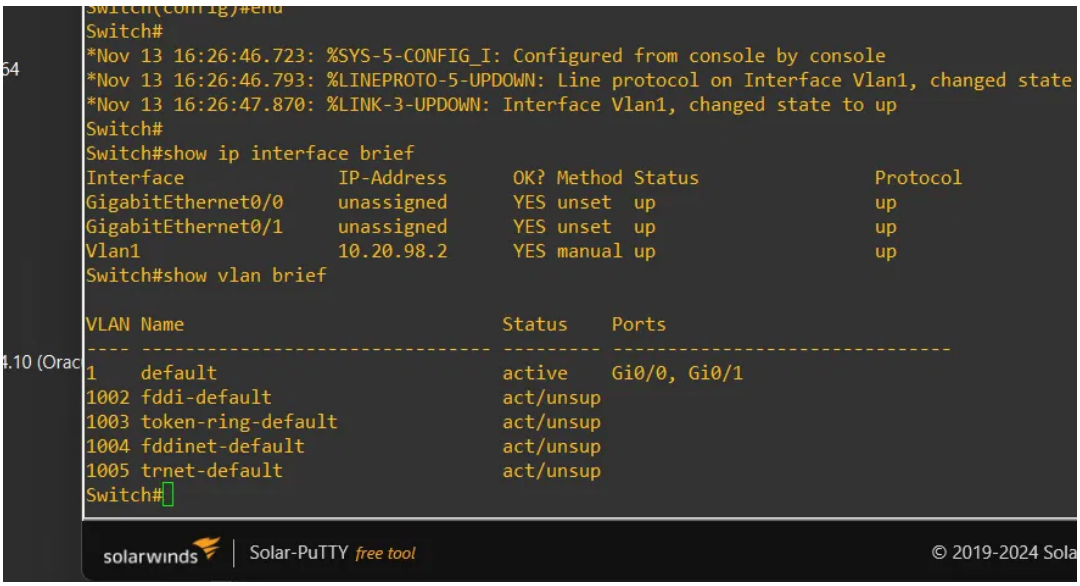


Figura 5. SW1 muestra VLAN 1 con direccion 10.20.98.2 y puertos de acceso activos.

4. Auditoria y referencias de control

La herramienta se ejecuta desde Kali y solicita credenciales SSH durante cada ejecucion. Las contrasenas no se guardan en informes. La evidencia de configuracion se recoge mediante comandos de lectura. Los informes JSON, CSV y HTML se escriben en un directorio por ejecucion.

Plataforma	Referencia cercana y alcance automatizado	Acciones elegibles en Apply
Cisco IOS	CIS Cisco IOS Benchmark v2.2, Level 1 (archivado y generico). IDs seleccionados: 1.1.2.1, 1.1.2.2, 1.1.2.3, 1.1.2.4, 1.1.3.3, 1.1.4.1, 1.2.2.5, 1.2.3.6 y 1.2.3.7.	Timeout VTY, banner MOTD y enable secret cuando el control falla y la accion esta implementada.
FortiGate	CIS FortiGate 7.0.x Benchmark v1.2.0 como referencia cercana; indicada por Fortinet como probada en 7.0.10. IDs seleccionados: 1.1, 2.1.1, 2.1.4, 2.1.5, 2.2.2, 2.4.4, 2.4.5 y 3.2.	Banner pre-login, hostname, bloqueo administrativo y timeout inactivo. DNS, NTP, interfaces y politicas requieren revision manual.

Estados: PASS = coincide con el criterio local; FAIL = no coincide; NOT_EVALUATED = evidencia insuficiente para decidir; ERROR = fallo de la operacion del escaneo. Un error de SSH no debe interpretarse como FAIL de configuracion.

Apply siempre ejecuta una auditoria PRE nueva; no usa un informe previo como fuente de estado. Presenta cambios y requiere escribir APPLY. Las modificaciones cubiertas por la implementacion afectan la configuracion activa; no se ejecuta write memory. Se respaldan en privado las secciones afectadas y se ejecuta POST. Si falla la verificacion de un control modificado, el programa intenta revertir ese control. No se modifica FortiGate port1.

5. Resultados observados y procedimiento

En una auditoria inicial registrada se observaron PASS=17, FAIL=8, NOT_EVALUATED=1 y ERROR=0. En una ejecucion posterior de Apply, la captura muestra el resumen PASS=23, FAIL=3, NOT_EVALUATED=0 y ERROR=0. El informe visible de SW1 todavia marcaba como FAIL el servidor HTTP habilitado (control 1.2.2.5). Estos conteos describen ejecuciones concretas y no deben generalizarse a otra corrida.

La evidencia de Apply muestra las acciones propuestas para R1 y SW1 (enable secret y MOTD), y para FW1 (banner pre-login y hostname FW1). La captura tambien muestra solicitudes para establecer secretos nuevos. No se publican los secretos introducidos.

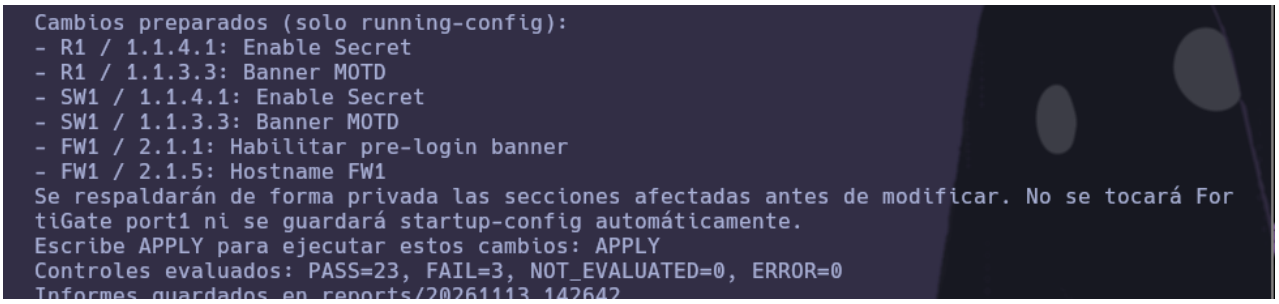


Figura 6. Resumen visible del plan/Apply y evidencia de resultado POST. La imagen fue recortada para excluir contenido ajeno al proyecto.

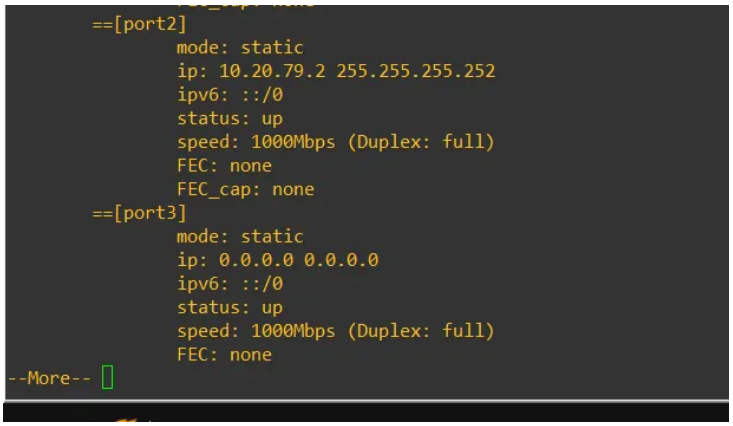


Figura 7. Estado observado de FortiGate: port2 en 10.20.79.2/30; port1 queda fuera del recorte.

6. Reproduccion y limites

Desde Kali Linux, dentro de la carpeta del proyecto, crear el entorno e instalar la dependencia documentada. El flujo de demostracion se ejecuta en este orden:

1	Audit Only PRE	./venv/bin/python scripts/auditor.py --mode audit --phase PRE
2	Vista de sugerencias	./venv/bin/python scripts/auditor.py --mode plan --phase PRE
3	Apply interactivo	./venv/bin/python scripts/auditor.py --mode apply
4	Verificacion independiente POST	./venv/bin/python scripts/auditor.py --mode audit --phase POST

Antes de usar Apply, revisar el plan y confirmar que existe acceso de administracion. Solo se escribe APPLY si se desea enviar los cambios. Mantener las copias privadas fuera de GitHub. Las configuraciones completas de los dispositivos no se incorporan porque no se recibieron como archivos; configs/ contiene fichas parciales de evidencia.

Referencias consultadas

CIS Cisco IOS Benchmark v2.2: https://www.cisecurity.org/-/jssmedia/Project/cisecurity/cisecurity/data/media/files/uploads/2017/04/CIS_Cisco_IOS_Benchmark_v22.pdf

CIS Fortinet Benchmarks: https://www.cisecurity.org/benchmark/fortinet

Fortinet, CIS benchmark para FortiGate: https://community.fortinet.com/fortigate-3/technical-tip-cis-benchmark-compliance-for-fortigate-200849

FortiOS 7.0.9 CLI Reference, config system global: https://docs.fortinet.com/document/fortigate/7.0.9/cli-reference/1620/config-system-global

FortiOS 7.0.9 Administration Guide, sincronizacion NTP: https://docs.fortinet.com/document/fortigate/7.0.9/administration-guide/336196

Archivos complementarios del repositorio: controles/alcance_cis.md, docs/TOPOLOGIA_TECNICA.md, docs/USO_EN_KALI.md, docs/EVIDENCIAS.md y scripts/README.md.